API Security Risk Analysis Report

Name : Vimal Raj R

Date: March 30, 2026

Target API: JSONPlaceholder

Executive Summary

Assessment Overview

This security assessment evaluated a publicly available API to identify vulnerabilities in authentication, authorization, data exposure, and request handling mechanisms. The analysis revealed critical security weaknesses that could enable unauthorized data access.

Key Findings

- Missing authentication controls
- Broken authorization (BOLA)
- Excessive data exposure
- Absence of rate limiting
- Weak input validation

Testing Scope: Public endpoints analyzed using read-only approach. No exploitation, DoS attacks, or unauthorized access attempts performed.

Testing Methodology

01

API Documentation Review

Endpoint mapping and functionality analysis

02

Endpoint Testing

Postman-based request testing

03

Response Inspection

Header analysis and data examination

04

Risk Identification

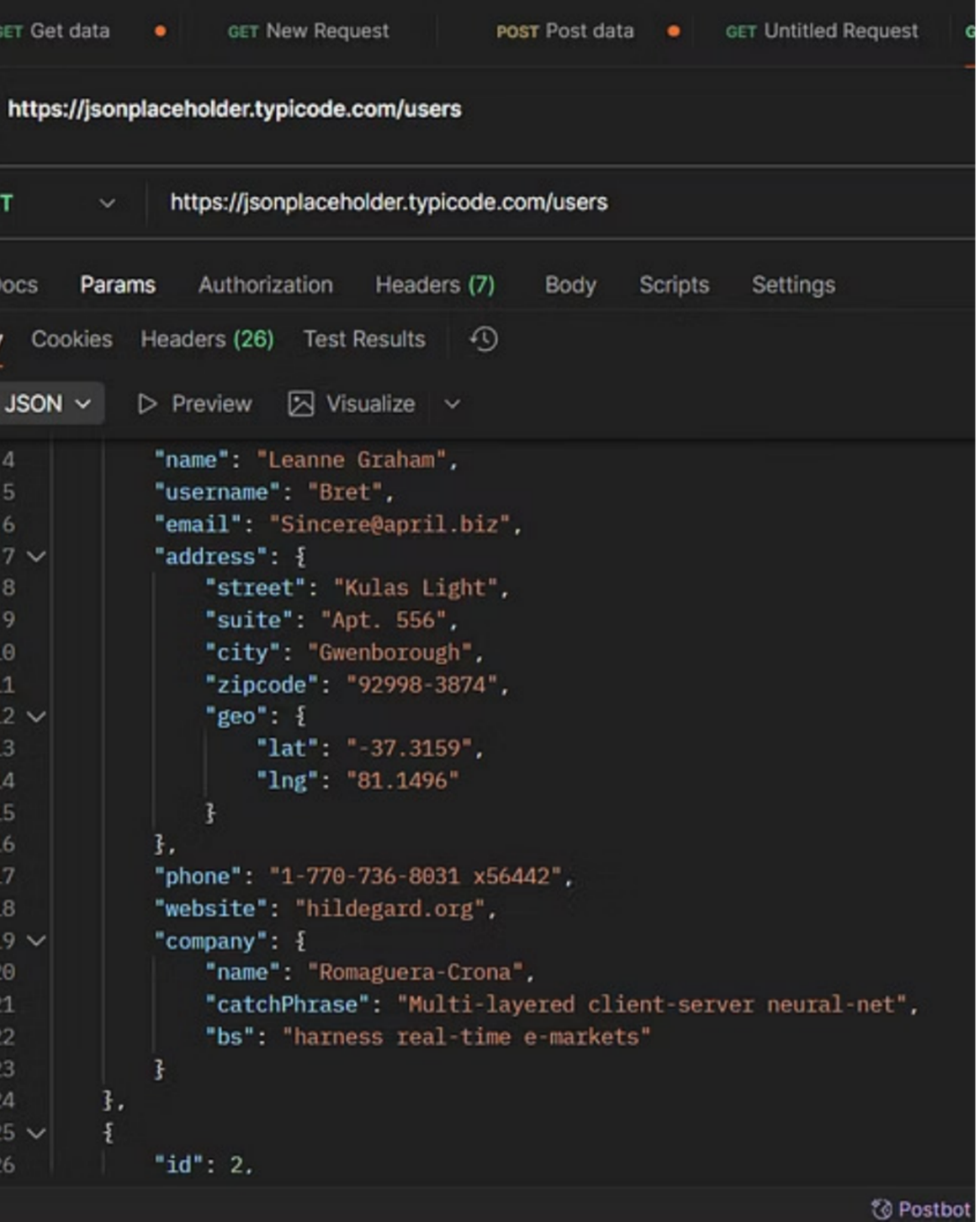
Vulnerability classification

05

Reporting

OWASP-aligned documentation

> **Sample Request:** GET https://jsonplaceholder.typicode.com/users — Returns full user dataset without authentication or restrictions



🔴 Finding 1: Missing Authentication

Severity: High

Description: API requires no authentication mechanism (API keys, tokens, or credentials) to access endpoints.

Impact: Unauthorized users can access complete API data without verification, creating unrestricted data exposure.

🔴 Finding 2: Broken Authorization (BOLA)

Severity: High

Description: API allows access to different users' data without verifying requester identity or permissions.

Example: GET /users/1 and GET /users/2 return full profiles without access controls.

Impact: Users can access other users' private data, resulting in severe privacy violations.

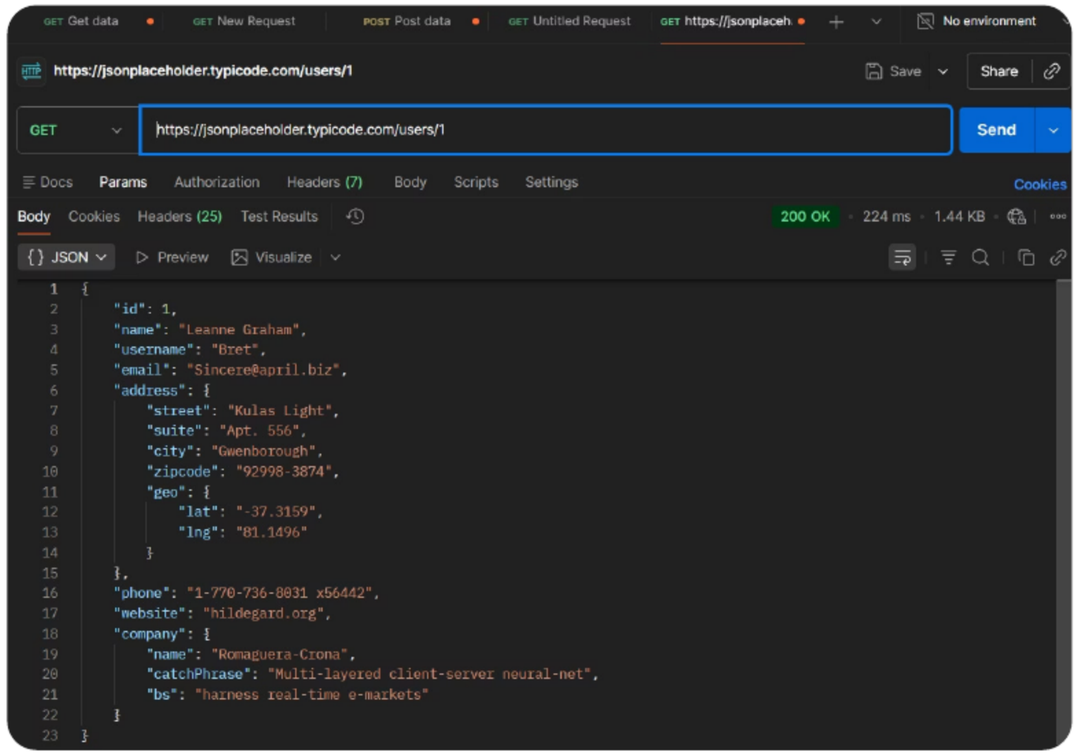
eaders (26) Test Results

Preview Visualize


```
},
"phone": "1-770-736-8031 x56442",
"website": "hildegard.org",
"company": {
    "name": "Romaguera-Crona",
    "catchPhrase": "Multi-layered client-server neural
    "bs": "harness real-time e-markets"
}


"id": 2,
"name": "Ervin Howell",
"username": "Antonette",
"email": "Shanna@melissa.tv",
"address": {
    "street": "Victor Plains",
    "suite": "Suite 879",
    "city": "Wisokyburgh",
    "zipcode": "90566-7771",
    "geo": {
        "lat": "-43.
        "lng": "-34.
    }
```

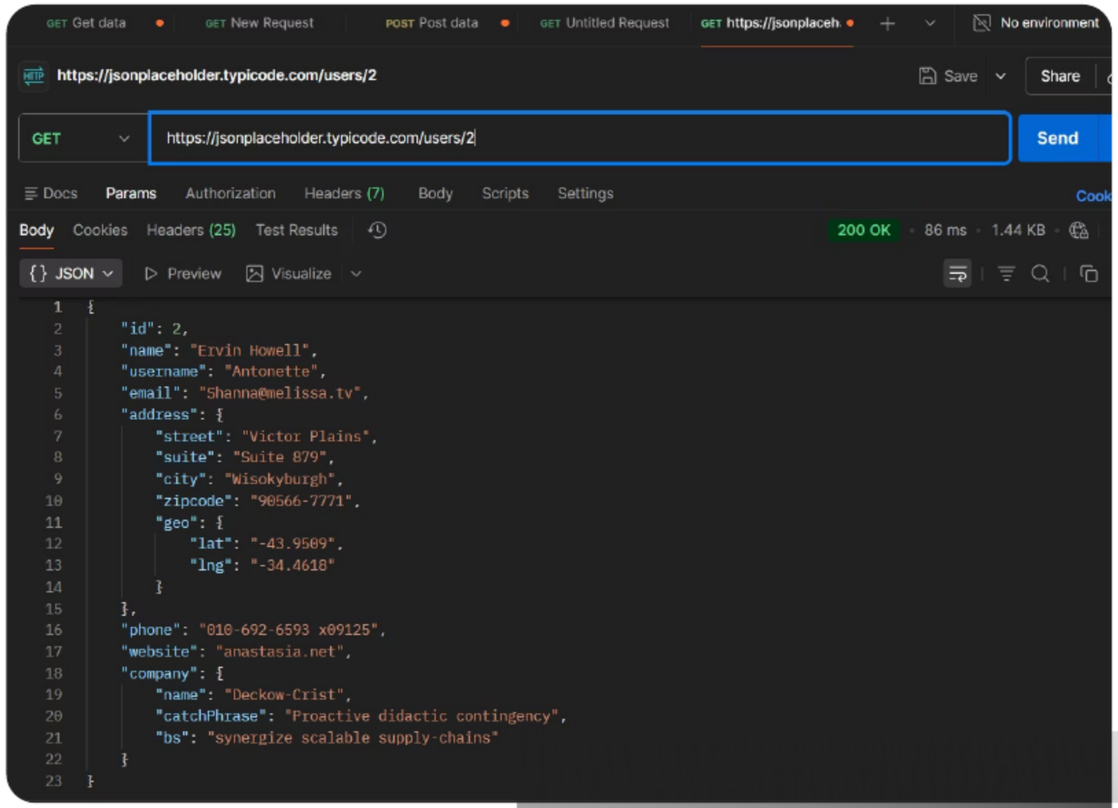
🟠 Finding 3: Excessive Data Exposure

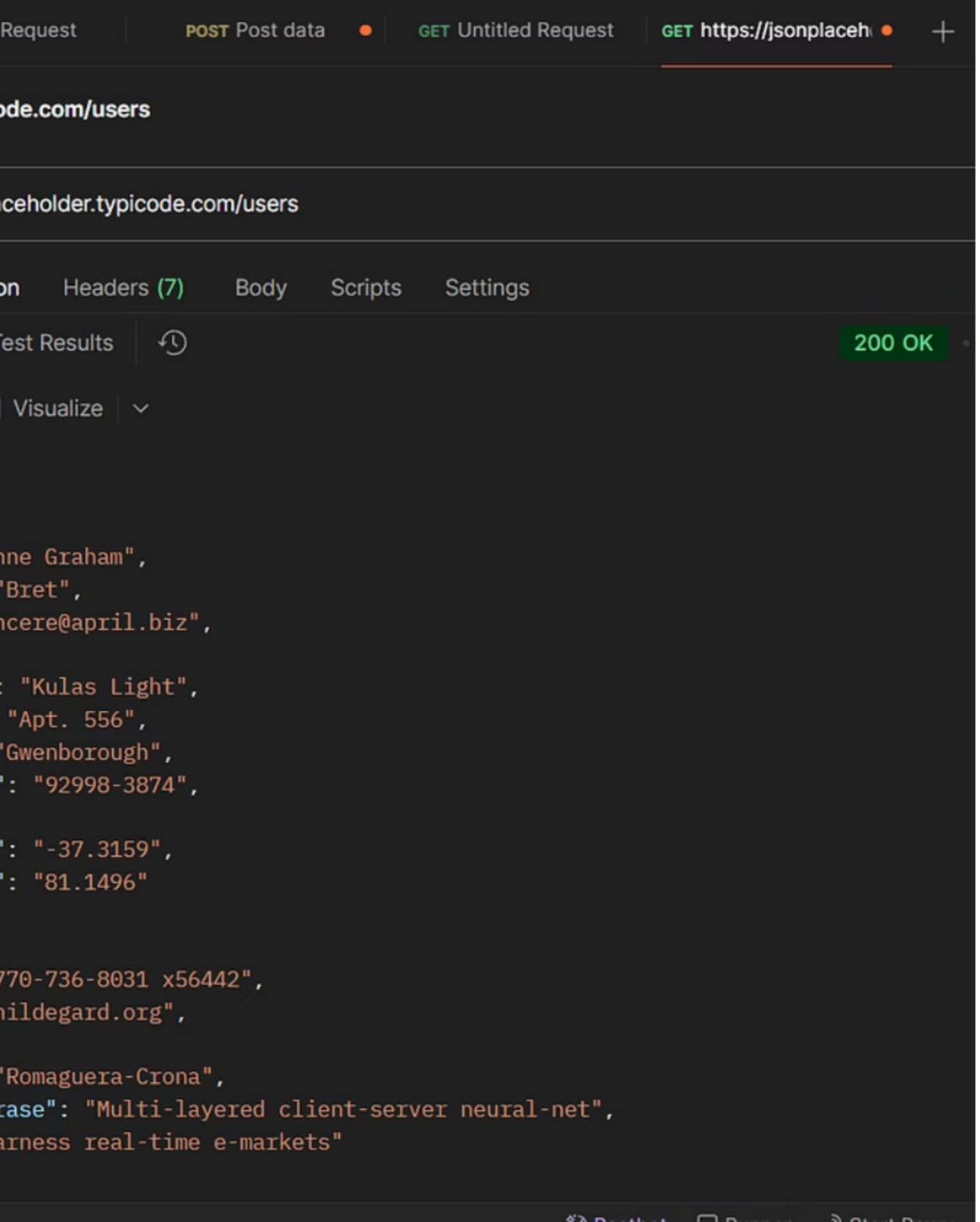


Severity: Medium

Description: API returns excessive user data including email addresses, full addresses, and contact information without field filtering.

Impact: Sensitive personally identifiable information (PII) exposed unnecessarily, increasing privacy risks and regulatory compliance issues.



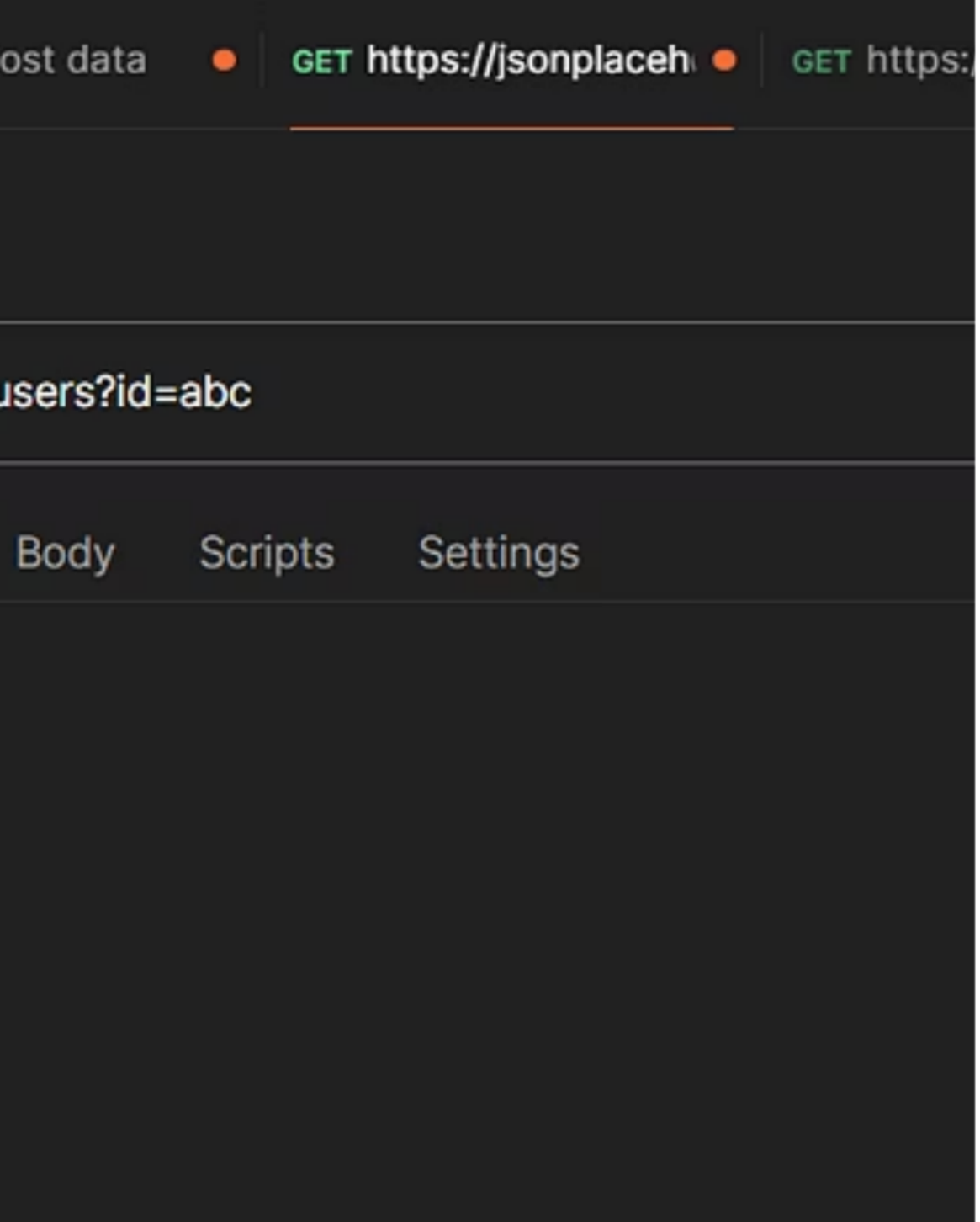


🟠 Finding 4: No Rate Limiting

Severity: Medium

Description: API imposes no restrictions on request frequency from individual clients or IP addresses.

Impact: Attackers can abuse API through excessive requests, causing denial-of-service conditions or incurring excessive infrastructure costs.



🟡 Finding 5: Input Validation Issues

Severity: Low

Description: API accepts invalid input without proper validation or sanitization mechanisms.

Example: GET /users?id=abc processes non-numeric input without error handling.

Impact: Improper input handling may lead to unexpected behavior, potential injection vulnerabilities, or server-side processing errors.

Risk Summary

Vulnerability	Severity	Business Impact
Missing Authentication	High	Unauthorized data access
Broken Authorization	High	Massive data leakage
Excessive Data Exposure	Medium	Privacy violations
No Rate Limiting	Medium	API abuse potential
Input Validation Issues	Low	Unexpected behavior

Recommendations Summary

1

Implement Authentication

Deploy JWT or OAuth 2.0 with token expiration

2

Enforce Authorization

Deploy RBAC with ownership validation

3

Limit Data Exposure

Implement field-level filtering

4

Add Rate Limiting

Set 100 requests/minute per IP

5

Validate Input

Deploy schema validation

Next Steps: Prioritize high-severity findings for immediate remediation. Conduct follow-up testing after implementing controls to verify effectiveness.